

Evidence Index

E-01 — securityheaders.com Scan

Tool	securityheaders.com
Target	https://demo.testfire.net/
Scan Date	21 May 2026 17:05:12 UTC
Overall Grade	F (Immediate action required)
IP Address	65.61.137.117

Screenshot

Security Report Summary



Site:

https://demo.testfire.net/

IP Address:

65.61.137.117

Report Time:

21 May 2026 17:05:12 UTC

Headers:

✖ Strict-Transport-Security

✖ Content-Security-Policy

✖ X-Frame-Options

✖ X-Content-Type-Options

✖ Referrer-Policy

✖ Permissions-Policy

Advanced:

Ouch, you should work on your security posture immediately:

Start Now

Missing Headers

Strict-Transport-Security

HTTP Strict Transport Security is an excellent feature to support on your site and strengthens your implementation of TLS by getting the User Agent to enforce the use of HTTPS. Recommended value "Strict-Transport-Security: max-age=31536000; includeSubDomains".

Content-Security-Policy

Content Security Policy is an effective measure to protect your site from XSS attacks. By whitelisting sources of approved content, you can prevent the browser from loading malicious assets.

X-Frame-Options

X-Frame-Options tells the browser whether you want to allow your site to be framed or not. By preventing a browser from framing your site you can defend against attacks like clickjacking. Recommended value "X-Frame-Options: SAMEORIGIN".

X-Content-Type-Options

X-Content-Type-Options stops a browser from trying to MIME-sniff the content type and forces it to stick with the declared content-type. The only valid value for this header is "X-Content-Type-Options: nosniff".

Referrer-Policy

Referrer Policy is a new header that allows a site to control how much information the browser includes with navigations away from a document and should be set by all sites.

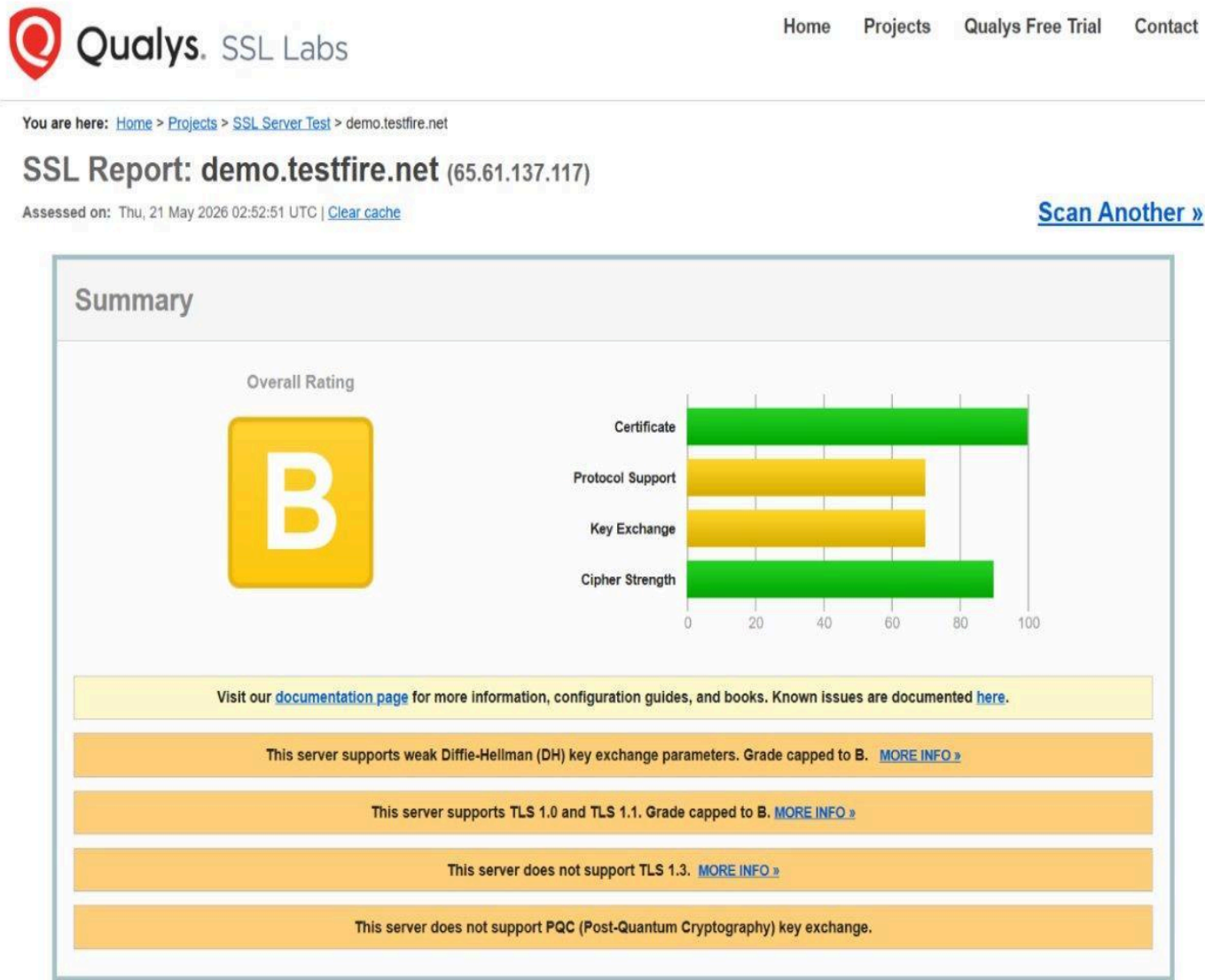
Permissions-Policy

Permissions Policy is a new header that allows a site to control which features and APIs can be used in the browser.

E-02 — Qualys SSL Labs Scan

Tool	Qualys SSL Labs (ssllabs.com/ssltest)
Target	demo.testfire.net (65.61.137.117)
Scan Date	21 May 2026 02:52:51 UTC
Overall Grade	B (Grade capped due to weak configuration)

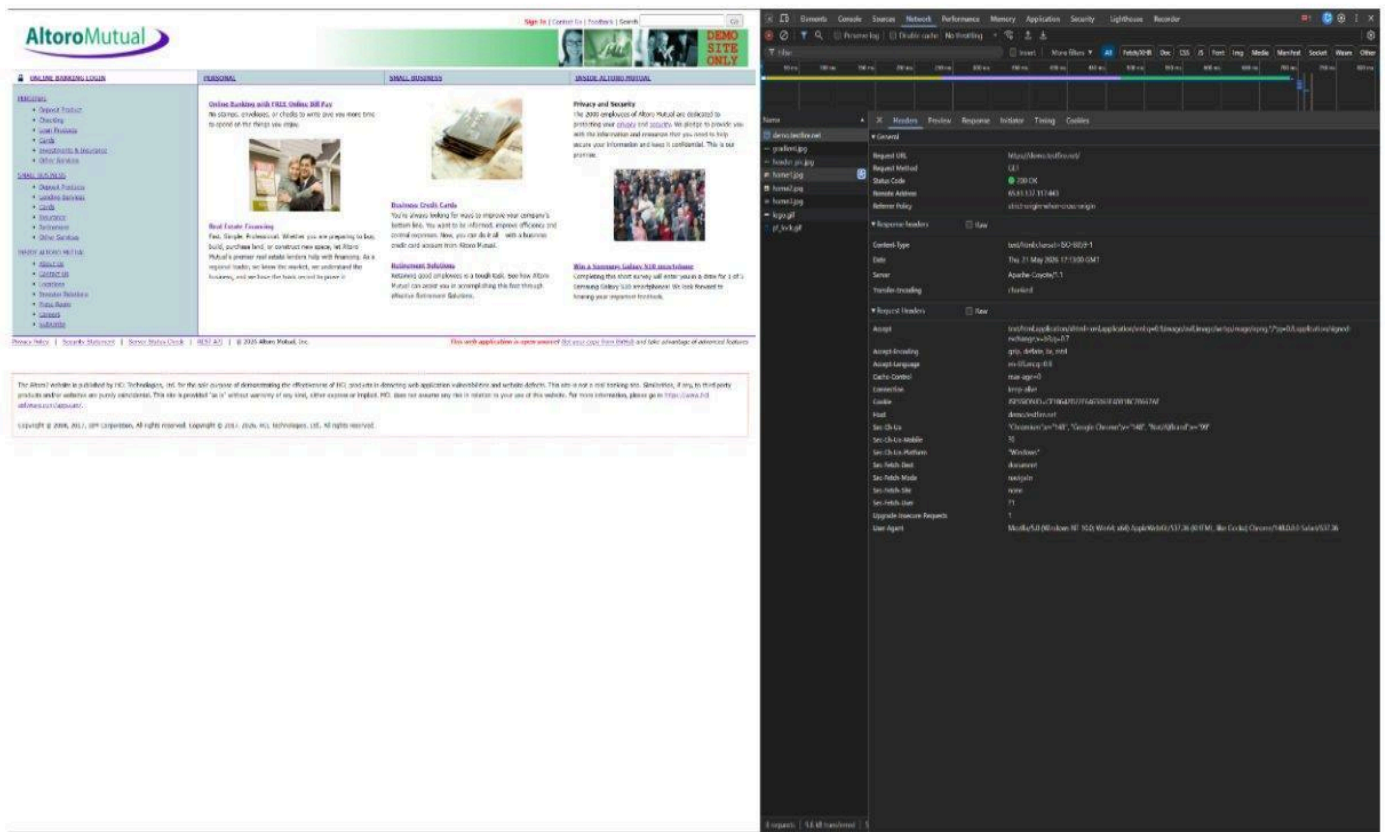
Screenshot



E-03 — Chrome DevTools Header Inspection

Tool	Google Chrome DevTools — Network Tab
Target	https://demo.testfire.net/
Capture Date	21 May 2026
Method	Passive header inspection — no interaction with the site

Screenshot



E-04 — MDN HTTP Observatory Report

Tool	MDN HTTP Observatory (observatory.mozilla.org)
Target	demo.testfire.net
Scan Date	21 May 2026
Overall Score	10 / 100 — Grade: F
Tests Passed	5 out of 10

Screenshot

mdn

HTML CSS JavaScript Web APIs All Learn Tools About Blog

Theme English (US)

HTTP Observatory > Report

Report Feedback

HTTP Observatory

Tests & Scoring

FAQ

HTTP Observatory Report

Scan summary: demo.testfire.net

F

Score: 10 / 100
Scan Time: Just now
Tests Passed: 5 / 10

Wait a minute to rescan

Scan another website

since last scan

Scan results

Scoring CSP analysis Cookies Raw server headers Scan history Benchmark comparison

Test	Score	Reason	Recommendation
Content Security Policy (CSP)	-25 ✖	Content Security Policy (CSP) header not implemented	Implement one, see MDN's Content Security Policy (CSP) documentation.
Cookies	0 ✔	All cookies use the <code>Secure</code> flag and all session cookies use the <code>HttpOnly</code> flag.	Use <code>SameSite</code> .
Cross Origin Resource Sharing (CORS)	0 ✔	Content is not visible via cross-origin resource sharing (CORS) files or headers.	None
Redirection	-20 ✖	Does not redirect to an HTTPS site.	Redirect to the same host on HTTPS first, then redirect to the final host on HTTPS.
Referrer Policy	-	<code>Referrer-Policy</code> header not implemented.	Set to <code>strict-origin-when-cross-origin</code> at a minimum.
Strict Transport Security (HSTS)	-20 ✖	<code>Strict-Transport-Security</code> header not implemented.	Add HSTS. Consider rolling out with shorter periods first (as suggested on https://hstspreload.org/).
Subresource Integrity	-	Subresource Integrity (SRI) is not needed since site contains no script tags.	None
X-Content-Type-Options	-5 ✖	<code>X-Content-Type-Options</code> header not implemented.	Set to <code>nosniff</code> .
X-Frame-Options	-20 ✖	<code>X-Frame-Options</code> (XFO) header not implemented.	Implement frame-ancestors CSP.
Cross Origin Resource Policy	-	Cross Origin Resource Policy (CORP) is not implemented (defaults to <code>cross-origin</code>).	None